

(c) Narrativa explicativa de la encuesta MITRE D3FEND

Hay encuestas que uno responde con la misma pasión que un formulario de aduanas y hay encuestas que, si se hacen bien, son un espejo incómodo. Esta aspira a lo segundo.

1. Por qué preguntar por D3FEND

MITRE D3FEND nació como la hermana introvertida de ATT&CK: menos glamour de conferencias, más obsesión por el detalle de cómo, exactamente, se defiende uno de algo.[web:1][web:2] Allí donde ATT&CK nos regala una taxonomía exquisita de técnicas ofensivas, D3FEND propone una ontología de contramedidas, sensores y vulnerabilidades que, bien usada, permite por fin poner números a la pregunta que todos fingen saber responder: "¿estamos razonablemente cubiertos?".[web:1][web:5]

La encuesta no pretende avergonzar a nadie (para eso ya están ciertas auditorías), sino cartografiar dónde estamos colectivamente: cuánto de D3FEND ha salido del PDF, cuánto se usa en herramientas y cuánto ha llegado al comité de dirección.[web:5][web:14]

2. Del mito del "cumplimiento" a la realidad de las coberturas

La regulación, desde NIS2 hasta las leyes nacionales de ciberseguridad, pide cosas razonables: gestión de riesgos, medidas técnicas y organizativas proporcionadas, notificación de incidentes, gobernanza responsable.[web:25][web:26][web:27] Lo que no siempre dice, al menos con la misma claridad, es con qué vocabulario describir ese esfuerzo.

El resultado es conocido: controles descritos en lenguaje genérico, informes llenos de adverbios y una cierta alergia a afirmar con precisión qué técnicas de ataque concretas se pueden detectar, mitigar o resistir. ATT&CK y D3FEND, juntos, ofrecen justamente ese vocabulario: uno para las tácticas del adversario, otro para nuestras defensas.[web:3][web:5][web:8]

La encuesta introduce preguntas incómodas pero necesarias: ¿tenemos un catálogo de técnicas ATT&CK prioritarias? ¿Sabemos qué contramedidas D3FEND cubren esas técnicas? ¿Lo medimos o lo intuimos? No se trata de aprobar un examen, sino de exponer el grado de distancia entre la narrativa de "madurez" y la realidad de las coberturas.

3. La gracia (y la miseria) de las métricas operativas

Las métricas que adoptan las organizaciones suelen dividirse en dos grupos: las que sirven para decorar dashboards ejecutivos y las que realmente cambian comportamientos. D3FEND empuja, por diseño, hacia las segundas: latencia de detección, tasa de éxito de mitigaciones, cobertura de telemetría, densidad de lagunas frente a ATT&CK.[web:5][web:18][web:21]

La encuesta no entra en fórmulas complejas, pero sí pregunta si esos indicadores existen, si se miden de forma sistemática y si alguien más, aparte del analista de guardia, los mira. Preguntar por MTTD, por MTTR o por recurrencia de incidentes no es fetichismo numérico: es una forma educada de preguntar si aprendemos algo de cada bofetada.[web:18][web:21]

4. D3FEND CAD y el fin del diagrama mudo

Durante años, las arquitecturas de seguridad han vivido atrapadas en diapositivas estáticas: cajas, flechas y una vaga promesa de que, en algún sitio, hay un firewall haciendo cosas heroicas. D3FEND CAD propone un salto cualitativo: grafos navegables que representan ataques, contramedidas, artefactos, sensores y debilidades con una semántica formal.[web:19][web:22][web:29]

La encuesta pregunta, sin disimulo, hasta qué punto hemos abandonado el PowerPoint como herramienta principal de modelado. No hace falta que toda organización tenga un ejército de ontólogos, pero sí que quienes hablan de "arquitectura defensiva" puedan, llegado el caso, mostrar un grafo en el que cada nodo tenga un nombre, una técnica y una razón de existir.[web:19][web:22]

5. OT, ICS y otras siglas donde el tiempo de parada es pecado mortal

Si en TI un fallo puede significar pérdida de datos o dinero, en OT un fallo puede significar interrupción de servicios esenciales o algo peor. La extensión de D3FEND a entornos OT no es un capricho intelectual, sino un intento serio de dotar de lenguaje común a un territorio donde las consecuencias de un ataque van más allá del balance trimestral.[web:5]

La encuesta distingue explícitamente entre organizaciones con y sin entornos OT y pregunta por métricas específicas: rutas de mando y control, cobertura de protocolos industriales, tiempos de recuperación. No porque sea divertido (que lo es, para cierto tipo de mente), sino porque ahí se juega buena parte de la resiliencia nacional.

6. Más allá del SOC: gobierno, cultura y dinero

Una defensa informada por amenazas que no llega al comité de dirección está condenada a quedarse en actividad heroica de unos pocos. De ahí las preguntas sobre qué órganos de gobierno revisan las métricas, con qué frecuencia y qué tipo de formación se ofrece en ATT&CK/D3FEND.[web:5][web:14]

De igual forma, preguntar por IGM y ROI no es un guiño a las obsesiones de consultoría, sino un reconocimiento de que, en última instancia, la seguridad compite por recursos con otras prioridades. Si podemos demostrar que invertir en determinadas contramedidas D3FEND reduce tiempos de detección, número de incidentes o impacto económico, el debate deja de ser religión y pasa a ser, por fin, gestión.[web:5][web:18][web:21]

7. Qué hacer con las respuestas

Una vez recogidas las respuestas, el verdadero trabajo comienza: limpiar datos, calcular indicadores, construir el IGM y, sobre todo, leer entre líneas las contradicciones. La plantilla de Excel propuesta ofrece un camino razonable para transformar casillas marcadas en algo parecido a conocimiento accionable.[web:18][web:21]

La idea no es publicar rankings humillantes, sino identificar patrones: sectores que miden mucho y cubren poco, sectores que cubren mucho pero miden poco, y, en ocasiones, honrosas excepciones que logran hacer ambas cosas sin perder del todo la cordura.

8. Epílogo: la encuesta como excusa

En realidad, la encuesta es una excusa. Una excusa para obligar a pensar en voz alta sobre cosas que se suelen discutir en pasillos o chats de emergencia: qué sabemos de nuestros adversarios, qué sabemos de nuestras defensas, qué números estamos dispuestos a mirar sin pestañear.

Si, al terminarla, alguien en su organización descubre que la respuesta honesta a demasiadas preguntas empieza por "no" o por "no lo sabemos", no lo tome como una derrota, sino como el principio de una agenda de trabajo. Al fin y al cabo, pocas cosas hay más peligrosas en ciberseguridad que una falsa sensación de madurez.